

NIST CSF 2.0

Small Business Cybersecurity Assessment

Everest Loom Textile Manufacturing

Textile Manufacturing | Texas, United States | 15 Employees

Prepared by

Sashwot Dhital

MS Cybersecurity Candidate, Webster University

[linkedin.com/in/sashwot-dhital](https://www.linkedin.com/in/sashwot-dhital)

August 2026

Independent portfolio project based on a fictional organization. No real company systems, records, customers, employees, or confidential information were assessed.

1. Executive Summary

For this portfolio project, I created a fictional textile company with 15 employees. The company uses Windows laptops, one accounting desktop, Microsoft 365, online banking, and shared spreadsheets for daily work. It does not have a dedicated cybersecurity employee, so technical problems are handled only when they occur.

I used the NIST Cybersecurity Framework (CSF) 2.0 to review this fictional environment. The project includes an asset inventory, a risk register, a gap assessment, and a basic improvement plan. The main concerns are common security basics, including account protection, backups, patching, employee awareness, and incident preparation.

Assessment briefly	Result
Framework applied	NIST Cybersecurity Framework (CSF) 2.0
Assets inventoried	8 (3 Critical, 4 High, 1 Medium)
Risks identified	7 (5 Critical, 1 High, 1 Medium)
Highest-scoring risks	R-01 Microsoft 365 without MFA (20) and R-06 No incident-response plan (20)
Weakest CSF Function	Protect (the only Function rated Critical priority)
Main cause	Basic controls and responsibilities are informal or inconsistent

1.1 Key Findings

- **Account security needs immediate attention:** MFA is not enabled on Microsoft 365, and employees share accounts or reuse passwords across email, the accounting computer, online banking, and laptops. A single compromised password could affect several critical systems.
- **Recovery capability is unverified:** Backups are inconsistent and restoration has not been tested, so the company cannot be confident that it could recover quickly from ransomware, hardware failure, or accidental deletion.
- **Incident response is undocumented:** Employees do not have a clear reporting path, contact list, or set of first actions to follow when a security event occurs.

- **Employee awareness is limited:** Staff receive little security-awareness training and do not have a simple, documented method for reporting suspicious messages.
- **Patching is inconsistent:** The company does not follow a documented update schedule, which may leave known vulnerabilities unaddressed for longer than necessary.

1.2 Main Takeaway

The company should start with practical actions. These include enabling multi-factor authentication, using individual accounts, improving backups, following a regular patching schedule, training employees, and creating a short incident-response plan. Actual cost and effort would depend on the company's existing services and IT support.

2. Company Profile and Assessment Scope

Everest Loom Textile Manufacturing is a fictional small business with 15 employees. It depends on a limited number of computers, cloud services, and shared files to manage orders, suppliers, inventory, and financial tasks.

Company	Everest Loom Textile Manufacturing	Employees	15
Industry	Textile manufacturing	Assessment date	August 2026
Location	Texas, United States (fictional)	Framework	NIST CSF 2.0

2.1 Business Operations and Technology Environment

Business Operations	Technology Environment
Textile production and scheduling	A small number of Windows laptops
Customer order processing	One dedicated accounting desktop
Supplier coordination	One wireless router providing all connectivity
Accounting and online banking	Two network printers

Inventory management	Microsoft 365 email and file sharing
Email communication with customers, suppliers, and staff	Online banking portal, inventory spreadsheet, customer and supplier records

2.2 Current Cybersecurity Posture

The following assumptions define the starting point for this fictional assessment:

- No dedicated cybersecurity employee; IT support is engaged reactively when problems occur
- Passwords are the primary and often only access control
- Files are shared informally through email attachments and USB drives
- Backups are performed inconsistently and restoration is not tested
- No documented incident-response plan exists; security-awareness training is limited
- Login activity is not routinely monitored

2.3 Scope

In scope: the business assets listed in Appendix A, including employee devices, Microsoft 365, online banking, the wireless network, customer and supplier records, the inventory spreadsheet, and removable media. The project also reviews basic administrative practices and the company's position across the six CSF 2.0 Functions.

Out of scope: physical security, manufacturing machinery, operational technology, supplier systems, penetration testing, vulnerability scanning, and technical validation of controls. This project is based only on the fictional company profile.

3. Methodology

3.1 Framework Selection

I selected NIST CSF 2.0 because it can be used by organizations of different sizes and does not require a specific product or tool. The Govern Function was useful for this scenario because several problems came from unclear responsibility and missing procedures. The report uses the six CSF Functions as an organizing structure:

Govern	Decide who is responsible and establish policies	Detect	Notice suspicious and harmful activity
Identify	Understand assets, systems, data, and risks	Respond	Act when an incident happens
Protect	Put safeguards in place	Recover	Restore operations and improve afterward

3.2 Assessment Process

I completed the project in four stages. First, I listed the company's important assets and noted what information they stored, who used them, and what could go wrong. Next, I identified seven risks, scored them with a simple likelihood-and-impact model, and connected them to relevant CSF categories. I then compared the fictional current state with a practical target state. Finally, I created a short list of recommended actions and a 90-day plan.

3.3 Risk Scoring Model

Risks were evaluated using a simplified likelihood-and-impact scoring model developed for this portfolio project. The scoring model is not an official NIST scoring methodology. Each risk received a likelihood score and an impact score from 1 to 5. I multiplied the two numbers to create a score from 1 to 25. The score was then placed into one of four levels:

Risk Level	Score Range	Interpretation
Critical	16 – 25	Immediate attention recommended
High	11 – 15	Address in the current planning cycle
Medium	6 – 10	Address as resources permit and monitor
Low	1 – 5	Accept or monitor with periodic review

All findings are based on the documented profile of the fictional organization. No systems were scanned, no logs were reviewed, no interviews were conducted, and no technical testing was performed.

4. Asset Inventory Summary

Eight assets were cataloged: three were rated Critical to business operations, four High, and one Medium. The full inventory appears in Appendix A. The five most business-critical assets are summarized below.

Asset	Type	Owner	Importance	Main Concern
Accounting computer	Hardware	Accountant	Critical	Unauthorized access or ransomware attack
Microsoft 365 email	Cloud service	Business owner	Critical	Phishing attacks or unauthorized access
Online banking portal	Financial service	Business owner	Critical	Credential theft
Customer records	Data	Sales team	High	Unauthorized disclosure
Inventory spreadsheet	Data	Operations manager	High	Deletion or incorrect changes

4.1 Observations

- Account protection is limited. Microsoft 365 and online banking mainly rely on passwords, even though these systems contain important communications and financial information.
- Responsibility is concentrated. The business owner is responsible for several important systems, which may create delays if tasks are not shared or documented.
- Data handling is informal. Customer records and the inventory spreadsheet are stored locally or in the cloud, but access permissions and version recovery are not clearly defined.
- USB use is not controlled. Employees may use personal USB drives to move files, and there is no standard approval or scanning process.

5. Risk Assessment Findings

I identified seven risks using the scoring method in Section 3.3. Five were rated Critical under this project model, one was rated High, and one was rated Medium. The table below shows the highest-priority items, while Appendix B contains the full risk register.

Risk Level	Count	Risk IDs
Critical (16–25)	5	R-01, R-02, R-04, R-05, R-06
High (11–15)	1	R-03
Medium (6–10)	1	R-07
Low (1–5)	0	None

5.1 Top Five Risks

ID	Threat or Weakness	Likelihood	Impact	Score	Level	CSF	Recommendation
R-01	Microsoft 365 does not use MFA	4	5	20	Critical	PR.AA	Enable MFA for all accounts
R-06	No documented incident-response plan	4	5	20	Critical	RS.MA	Create a basic incident-response plan
R-02	Employees use shared accounts or reused passwords	4	4	16	Critical	PR.AA	Require individual accounts and stronger passwords
R-04	Computers may not receive patches regularly	4	4	16	Critical	PR.PS	Establish monthly patching procedures

R-05	Employees receive limited security-awareness training	4	4	16	Critical	PR.AT	Provide awareness training and a reporting process
-------------	---	---	---	-----------	-----------------	-------	--

6. NIST CSF Gap Assessment

The fictional current state was compared with a practical target state for each CSF Function. This helped show where the largest gaps existed and which areas should be addressed first. Appendix C contains the full gap-assessment table.

Function	Main Gap	Target State	Priority
Govern (GV)	Governance is informal (no policy, no assigned owner)	Business owner approves a basic policy and assigns responsibilities	High
Identify (ID)	No documented inventory or risk assessment	Maintain an asset inventory and review risks regularly	High
Protect (PR)	Safeguards are incomplete or inconsistent	MFA, least privilege, patching, backups, and training	Critical
Detect (DE)	Limited monitoring; events noticed only after a problem	Configure sign-in alerts and establish a regular review process	High
Respond (RS)	Response depends on improvisation	Create an incident-response checklist and contact list	High
Recover (RC)	Recovery reliability is unknown and untested	Perform scheduled backups and periodic restoration tests	High

7. Recommended Actions

The following actions address the highest-scoring risks and are reasonable starting points for a small business. Some tasks may require help from an IT provider, and the cost would depend on the company's current tools and service agreements.

#	Action	Addresses	CSF	Est. Cost	Owner and Rationale
1	Enable MFA on Microsoft 365 and confirm the strongest available MFA for online banking	R-01, R-02	PR.AA	Low / depends on licensing	Business owner with IT support. Reduces reliance on passwords for critical accounts.
2	Issue individual accounts and enforce strong unique passwords	R-02	PR.AA	Low	Business owner with IT support. Improves accountability and limits the impact of one compromised credential.
3	Schedule automated backups and test restoration	R-03	PR.IR, RC.RP	Low	Operations manager. Establishes a verified recovery process rather than relying on assumptions.
4	Establish a monthly patching procedure	R-04, R-07	PR.PS	Staff time / IT support	IT support provider. Keeps systems on a documented update cycle.
5	Write a one-page incident-response plan and deliver phishing training	R-05, R-06	RS.MA, PR.AT	None to low	Business owner. Gives employees a clear reporting path and basic response guidance.

The 90-day plan also includes sign-in alerts and basic rules for USB devices. These actions come after the most important account, backup, and patching tasks.

8. Suggested 90-Day Plan

The recommendations are grouped into three phases so the company can focus on a few tasks at a time. This is a suggested plan for the fictional scenario, not a guaranteed implementation schedule.

Timeframe	Main Actions	Suggested Owner	Evidence of Completion
Days 1 to 30	Enable MFA, remove shared accounts, reset reused passwords, and document current backups.	Business owner with IT support	MFA is active, every employee has a named account, and backup locations are documented.
Days 31 to 60	Schedule backups, test one restoration, apply system updates, provide phishing training, and enable sign-in alerts.	Operations manager and IT support	A file is restored, updates are logged, and employees know how to report suspicious email.
Days 61 to 90	Write a short incident-response plan, assign a security owner, define USB rules, and review the risk register.	Business owner and assigned security owner	The plan is approved, responsibilities are assigned, and the risks are reviewed using completed evidence.

Expected outcome after 90 days: the company should have better account security, more reliable backups, a regular patching process, basic employee training, and a short incident-response plan. The risks should then be reviewed again using evidence from the completed tasks. The company would still have more work to do, but its security practices would be more organized than at the start.

9. Limitations

This assessment should be read with the following constraints in mind.

- **Fictional organization:** Everest Loom Textile Manufacturing does not exist. No real systems, employees, customers, or confidential records were assessed.
- **Simplified scoring and judgment:** The likelihood and impact ratings were created for this learning project. They are not an official NIST scoring method, and another person could reasonably choose different scores.

- Limited scope: No scanning, penetration testing, log review, interviews, or control testing was performed. The project used selected CSF categories and did not cover physical security, operational technology, supply-chain risk, or legal compliance.

10. Conclusion

This project helped me practice connecting business assets, cybersecurity risks, NIST CSF categories, and practical recommendations. In the fictional scenario, the most important issues were basic controls such as account security, backups, patching, employee awareness, and incident preparation.

The project is not a real audit and the scores are not verified findings. Its value is the process I followed: understand the business, identify important assets, consider possible risks, compare the current and target states, and choose realistic improvements.

A reasonable next step for the fictional company would be to assign one person to coordinate security tasks and begin with the first 30-day actions.

11. References

National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework (CSF) 2.0 (NIST CSWP 29). U.S. Department of Commerce.
<https://doi.org/10.6028/NIST.CSWP.29>

National Institute of Standards and Technology. (2024). Small business quick-start guide: NIST Cybersecurity Framework 2.0 (NIST SP 1300). U.S. Department of Commerce.
<https://doi.org/10.6028/NIST.SP.1300>

These sources supported the framework and risk-assessment approach used in this project. No real company records or systems were reviewed.

Appendix A: Full Asset Inventory

Everest Loom Textile Manufacturing: complete asset register (8 assets).

Asset	Type	Owner	Information Stored	Importance	Existing Protection	Main Concern
Accounting computer	Hardware	Accountant	Financial records	Critical	Password, antivirus	Unauthorized access or ransomware attack
Microsoft 365 email	Cloud service	Business owner	Communications and attachments	Critical	Password	Phishing attacks or unauthorized access
Online banking	Financial service	Business owner	Banking transactions	Critical	Password	Credential theft
Customer records	Data	Sales team	Names, orders, and contact details	High	Cloud storage; access controls not formally reviewed	Unauthorized disclosure
Inventory spreadsheets	Data	Operations manager	Stock and supplier information	High	Local and cloud copies; version recovery not confirmed	Deletion or incorrect changes
Wireless router	Network device	Business owner	Network connectivity	High	Wi-Fi password; configuration not formally reviewed	Weak configuration

Employee laptops	Hardware	Employees	Emails and business files	High	Password, antivirus	Device loss or malware
USB drives	Removable media	Various employees	Business files	Medium	No standard controls	Malware introduction, data loss, or corruption

Appendix B: Full Risk Register

Scoring: Likelihood × Impact, each rated 1–5. Levels: 1–5 Low, 6–10 Medium, 11–15 High, and 16–25 Critical. This simplified model was created for the portfolio project and is not an official NIST scoring methodology.

B.1 Risks, Assets, and Business Impact

ID	Threat or Weakness	Associated Assets	Possible Business Impact
R-01	Microsoft 365 does not use MFA	Microsoft 365 email	Attacker could read email, impersonate the employee, access shared files, or send fraudulent payment requests
R-02	Employees use shared accounts or reused passwords	Email, accounting computer, online banking, employee laptops	Unauthorized access across multiple systems, limited accountability, or exposure of financial and customer data
R-03	Backups are inconsistent and untested	Accounting computer, inventory spreadsheet, customer records	Loss of business data
R-04	Computers may not receive patches regularly	Accounting computer, employee laptops	Known vulnerabilities may remain exposed, increasing the chance of malware or system disruption

R-05	Employees receive limited security-awareness training	Employees, Microsoft 365 email, employee laptops	Credential disclosure, malicious attachment execution, or delayed reporting of suspicious messages
R-06	No documented incident-response plan	Overall company assets	Delayed or inconsistent containment, recovery, and communication
R-07	Personal USB devices may be used without controls	USB drives, employee laptops	Malware introduction, unauthorized copying, data loss, or corruption

B.2 Scoring, Classification, and Recommendations

ID	Likelihood	Impact	Score	Risk Level	CSF Mapping	Recommendation
R-01	4	5	20	Critical	PR.AA	Enable MFA for all accounts
R-02	4	4	16	Critical	PR.AA	Require individual accounts and stronger passwords
R-03	3	5	15	High	PR.IR, RC.RP	Schedule backups and test restoration
R-04	4	4	16	Critical	PR.PS	Establish monthly patching procedures
R-05	4	4	16	Critical	PR.AT	Provide awareness training and a reporting process
R-06	4	5	20	Critical	RS.MA	Create a short incident-response plan
R-07	3	3	9	Medium	PR.DS, PR.PS	Limit and scan approved removable media

Appendix C: Full NIST CSF 2.0 Gap Assessment

Function	Current State	Target State	Main Gap	Priority
Govern (GV)	No formal cybersecurity policy or assigned owner	Business owner approves a basic policy and assigns responsibilities	Governance is informal	High
Identify (ID)	Assets and risks are known informally	Maintain an asset inventory and review risks on a regular basis	No documented inventory or assessment	High
Protect (PR)	Passwords and antivirus provide basic protection	MFA, least privilege, patching, backups, and training	Safeguards are incomplete or inconsistent	Critical
Detect (DE)	Security events are checked mainly after a problem	Configure sign-in alerts and establish a regular review process	Limited monitoring	High
Respond (RS)	Employees do not have a documented reporting process	Create an incident-response checklist and contact list	Response depends on improvisation	High
Recover (RC)	Backups are inconsistent and restoration is not tested	Perform scheduled backups and periodic restoration tests	Recovery capability is unverified	High